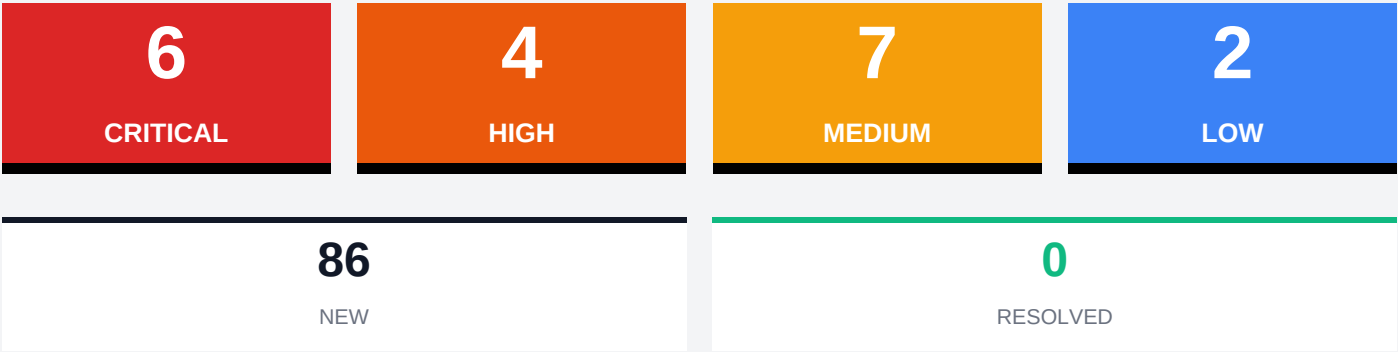




nathirkasim/clean-repo

Branch: all branches
All Time



OPTIONS: Executive summary

SCA - VULNERABLE DEPENDENCIES



10 records

CRITICAL	OPEN	CVE-2026-22732	main
org.springframework.security:spring-security-web 6.2.4			
Spring Security: Spring Security: Security policy bypass and information disclosure due to unwritten HTTP headers			
Fix available: 7.0.4			
CRITICAL	OPEN	CVE-2024-38821	main
org.springframework.security:spring-security-web 6.2.4			
Spring-WebFlux: Authorization Bypass of Static Resources in WebFlux Applications			
Fix available: 6.3.4			
CRITICAL	OPEN	CVE-2026-43515	main
org.apache.tomcat.embed:tomcat-embed-core 10.1.20			
tomcat-coyote: tomcat: Improper Authorization allows security bypass			
Fix available: 11.0.22			

CRITICAL OPEN CVE-2026-43512	main
org.apache.tomcat.embed:tomcat-embed-core 10.1.20 tomcat-coyote: Apache Tomcat: Authentication bypass via digest authentication Fix available: 11.0.22	
CRITICAL OPEN CVE-2026-41293	main
org.apache.tomcat.embed:tomcat-embed-core 10.1.20 tomcat-coyote: Apache Tomcat: HTTP/2 request headers not validated Fix available: 11.0.22	
CRITICAL OPEN CVE-2025-24813	main
org.apache.tomcat.embed:tomcat-embed-core 10.1.20 tomcat: Potential RCE and/or information disclosure and/or information corruption with partial PUT Fix available: 11.0.3	
HIGH OPEN CVE-2026-41845	main
org.springframework:spring-webmvc 6.1.6 org.springframework: Spring Framework: Cross-site scripting (XSS) via incorrect JavaScript escaping Fix available: 7.0.8	
HIGH OPEN CVE-2026-41842	main
org.springframework:spring-webmvc 6.1.6 spring-framework: Spring Framework: Denial of Service when resolving static resources Fix available: 7.0.8	
HIGH OPEN CVE-2024-38819	main
org.springframework:spring-webmvc 6.1.6 org.springframework:spring-webmvc: Path traversal vulnerability in functional web frameworks Fix available: 6.1.14	
HIGH OPEN CVE-2024-38816	main
org.springframework:spring-webmvc 6.1.6 spring-webmvc: Path Traversal Vulnerability in Spring Applications Using RouterFunctions and FileSystemResource Fix available: 6.1.13	

SAST, SECRETS & IAC - COMBINED FINDINGS

0 CRITICAL	0 HIGH	7 MEDIUM	2 LOW
----------------------------------	------------------------------	--------------------------------	-----------------------------

9 records

MEDIUM	OPEN	gitlab.find_sec_bugs.HARD_CODE_KEY-3	main
Cryptographic keys should not be kept in the source code. The source code can be widely shared in an enterprise environment, and is certainly shared in open source. To be managed safely, passwords and secret keys should be stored in separate configuration files or keystores. java/src/main/java/com/example/cleanrepo/UserService.java:64 CWE-321: Use of Hard-coded Cryptographic Key · security · 2026-09-02			
MEDIUM	OPEN	yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-...	main
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. .github/workflows/ci.yml:37 CWE-1357: Reliance on Insufficiently Trustworthy Component · security · 2026-09-02			
MEDIUM	OPEN	yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-...	main
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. .github/workflows/ci.yml:32 CWE-1357: Reliance on Insufficiently Trustworthy Component · security · 2026-09-02			
MEDIUM	OPEN	yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-...	main
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. .github/workflows/ci.yml:27 CWE-1357: Reliance on Insufficiently Trustworthy Component · security · 2026-09-02			
MEDIUM	OPEN	yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-...	main
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. .github/workflows/ci.yml:22 CWE-1357: Reliance on Insufficiently Trustworthy Component · security · 2026-09-02			
MEDIUM	OPEN	yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-...	main
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. .github/workflows/ci.yml:19 CWE-1357: Reliance on Insufficiently Trustworthy Component · security · 2026-09-02			

MEDIUM	OPEN	KSV-0125	main
Ensure that all containers use images only from trusted registry domains.			
k8s/deployment.yaml		Restrict container images to trusted regi...	
2026-09-02			

LOW	OPEN	javascript.express.security.audit.express-check-csrf-middleware-usage.express-check-csrf-...	main
A CSRF middleware was not detected in your express application. Ensure you are either using one such as `csrf` or `csrf` (see rule references) and/or you are properly doing CSRF validation in your routes with a token or cookies.			
nodejs/src/server.js:6			
CWE-352: Cross-Site Request Forgery (CSRF) · security · 2026-09-02			

LOW	OPEN	AWS-0089	main
Ensures S3 bucket logging is enabled for S3 buckets			
terraform/main.tf		S3 Bucket Logging	
2026-09-02			